Information Security CSC232

LECTURE-7 20-OCT-2026

SAAD MALIK

Lecture Contents

Part 1: Firewall Fundamentals
- Purpose and operation of firewalls
- Design goals and access control techniques
- Capabilities and limitations
- Firewall generations

Part 2: Types of Firewalls
- Packet-filtering firewalls (static, dynamic, stateful)
- Application-level gateways and circuit gateways
- MAC layer and hybrid firewalls
- Bastion hosts, host-based, personal, and distributed firewalls

Part 3: Firewall Rules and Network Protection
- Source/destination addresses and ports
- Allow and deny rules
- DMZ and NAT
- Firewall rule ordering
- Firewall architectures

The Need for Firewalls

Evolution of Organizational Networks:

1. Centralized data processing — central mainframe with directly connected terminals
2. Local area networks (LANs) — interconnecting PCs and terminals
3. Premises network — multiple LANs interconnecting PCs, servers, mainframe
4. Enterprise-wide network — multiple geographically distributed premises networks interconnected by private WAN
5. Internet connectivity — premises networks hook into the Internet

The Problem:

- Internet connectivity is **no longer optional**
- Internet access enables the outside world to **reach and interact** with local network assets
- This creates a **threat** to the organization

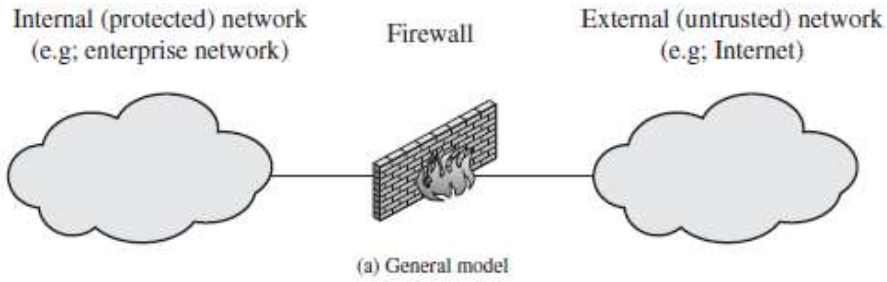
Key Insight:

Equipping each workstation with strong security features (intrusion protection) may not be sufficient and in some cases is **not cost-effective** — especially with hundreds or thousands of systems running various operating systems.

What is a Firewall?

- Definition:
A firewall in an information security program prevents specific types of information from moving between the outside world (untrusted network) and the inside world (trusted network).

- Definition:
Firewalls can be an effective means of protecting a local system or network of systems from network-based security threats while at the same time affording access to the outside world via wide area networks and the Internet.



(a) General model

- Real-World Analogy:
  - Building firewall: Concrete or masonry walls from basement through roof to prevent fire spreading
  - Aircraft/automobile firewall: Insulated metal barrier keeping hot/dangerous moving parts separate from inflammable interior
  - Information security firewall: Prevents specific types of information from moving between untrusted and trusted networks
- Physical Forms:
  - A separate computer system
  - A software service running on an existing router or server
  - A separate network containing a number of supporting devices

Firewall Design Goals

Three Design Goals ():

1. **All traffic from inside to outside, and vice versa, must pass through the firewall.**
   - Achieved by physically blocking all access to the local network except via the firewall

2. **Only authorized traffic, as defined by the local security policy, will be allowed to pass.**
   - Various types of firewalls implement various types of security policies

3. **The firewall itself is immune to penetration.**
   - Implies use of a **hardened system** with a **secured operating system**
   - Trusted computer systems are suitable for hosting a firewall

Key Concept: Firewall provides an additional layer of defense — the classic military doctrine of **"defense in depth."**

Firewall Access Control Techniques

Four General Techniques:

Technique	Description	Example
Service Control	Determines types of Internet services that can be accessed (inbound or outbound)	Filter traffic by IP address, protocol, or port; proxy software; host server software
Direction Control	Determines direction in which particular service requests may be initiated and allowed to flow	Inbound vs. outbound rules
User Control	Controls access to a service according to which user is attempting to access it	Applied to local users; external users require secure authentication (e.g., IPSec)
Behavior Control	Controls how particular services are used	Filter e-mail to eliminate spam; enable external access to only a portion of a Web server

Key Point: Originally, firewalls focused primarily on **service control but** have since evolved to provide all four.

Firewall Capabilities

What a Firewall Can Do:

1. **Define a single choke point** — keeps unauthorized users out, prohibits potentially vulnerable services, provides protection from IP spoofing and routing attacks
   - Simplifies security management because capabilities are consolidated

2. **Provide a location for monitoring security-related events** — audits and alarms can be implemented

3. **Provide a convenient platform for non-security Internet functions** — network address translator (NAT), network management function

4. **Serve as the platform for IPSec** — using tunnel mode to implement virtual private networks (VPNs)

Key Point: The firewall establishes a controlled link and erects an **outer security wall or perimeter** between the premises network and the Internet.

Firewall Limitations

What a Firewall Cannot Do:

1. **Cannot protect against attacks that bypass the firewall**
   - Internal systems may have dial-out or mobile broadband capability to connect to an ISP
   - Internal LAN may support a modem pool for dial-in access
2. **May not protect fully against internal threats**
   - Disgruntled employee
   - Employee who unwittingly cooperates with an external attacker
3. **An improperly secured wireless LAN may be accessed from outside**
   - Internal firewall cannot guard against wireless communications between local systems on different sides
4. **Portable devices may be infected outside and used internally**
   - Laptop, PDA, or portable storage device

Additional Limitation:

- Firewalls cannot protect against attacks that bypass the firewall (e.g., dial-up connections)
- Unsecured dial-up connection points represent a substantial exposure to attack
- **War dialer** — automatic phone-dialing program that dials every number in a configured range to locate connection points

Firewall Generations

Five Generations of Firewalls:

Generation	Type	Description
First	Static Packet-Filtering	Simple networking devices that filter packets according to headers
Second	Application-Level / Proxy Servers	Dedicated systems separate from filtering router; provide intermediate services
Third	Stateful Inspection	Monitor network connections between internal and external systems using state tables
Fourth	Dynamic Packet-Filtering	Allow only a particular packet with particular source, destination, and port address to enter
Fifth	Kernel Proxy	Evaluates packets at multiple layers of protocol stack; checks security in kernel as data passes up and down the stack

Fifth Generation — Cisco Centri Firewall:
Contains three component technologies:

- **Interceptor/Packet Analyzer** — captures packets, reads header, extracts signature data
- **Security Verification Engine (SVEN)** — determines whether to drop packet, map to existing session, or create new session
- **Kernel Proxies** — temporary protocol stack with customized NAT implementation

Hybrid Firewalls — The Practical Reality

Definition:

Hybrid firewalls combine elements of other types of firewalls — packet filtering and proxy services, or packet filtering and circuit gateways.

Key Point:

In practice, **most firewalls fall into this category**, since most firewall implementations use multiple approaches.

Example Configuration:

- A hybrid firewall system may consist of **two separate firewall devices**
- Each is a separate firewall system, but they are connected so they work in tandem
- Example: Packet-filtering firewall screens acceptable requests → passes to proxy server → proxy requests services from Web server deep inside network

Advantage:

Enables an organization to make a security improvement **without completely replacing existing firewalls**.

TYPES OF FIREWALLS: Packet-Filtering Firewalls

Definition:

Examines the header information of data packets that come into a network. Determines whether to **drop a packet (deny)** or **forward it to the next network connection (allow)** based on rules programmed into the firewall.

How It Works:

- Functions at the **IP level** (Layer 3 of OSI model)
- Examines every incoming packet header
- Selectively filters based on:
  - IP source and destination address
  - Direction (inbound or outbound)
  - Protocol (IP protocol layer)
  - TCP or UDP source and destination port requests

Restrictions Most Commonly Implemented:

- IP source and destination address
- Direction (inbound or outbound)
- Protocol
- TCP/UDP source and destination port requests

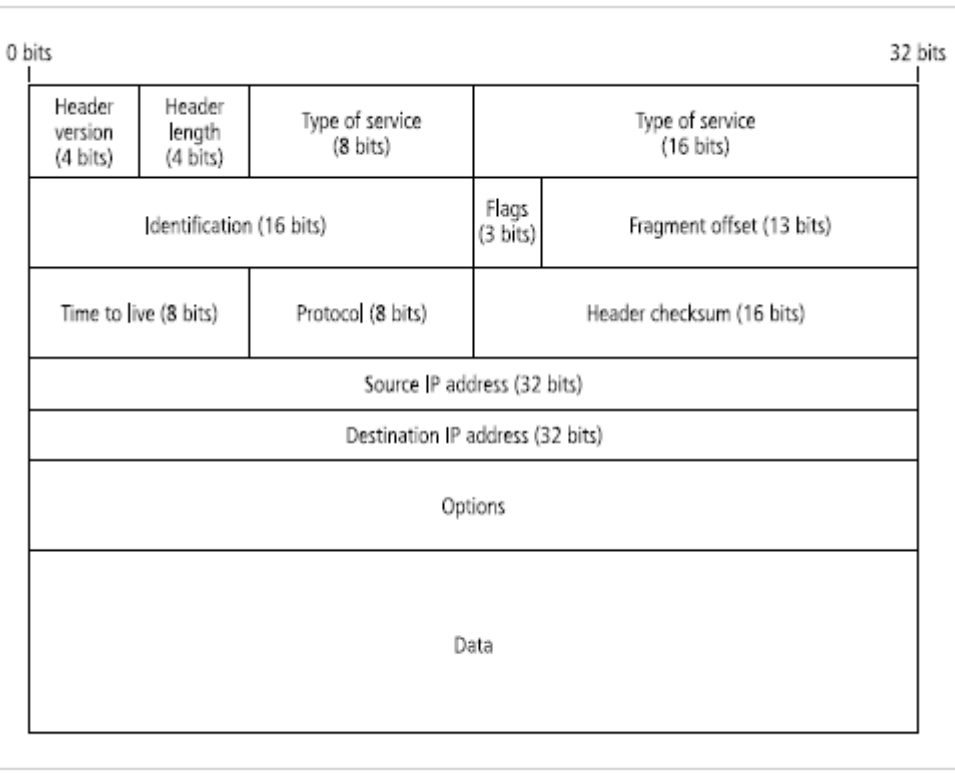


Figure 6-2 IP Packet Structure

Key Point: If the device finds a packet that matches a restriction, it **stops the packet** from traveling from one network to another.

Static Filtering

Definition:
Requires that the filtering rules be **developed and installed** with the firewall.

How Rules Are Created:

- By a person directly editing the rule set
- By a person using a programmable interface to specify rules and sequence

Key Characteristic:
Any changes to the rules require **human intervention**.

Common Use:
Network routers and gateways.

Example Firewall Rule Format (Table 6-1):

Source Address	Destination Address	Service	Action
172.16.x.x	10.10.x.x	Any	Deny
192.168.x.x	10.10.10.25	HTTP	Allow
192.168.0.1	10.10.10.10	FTP	Allow

Key Point: Simple firewall models examine two aspects of packet header — destination and source address. They enforce **address restrictions** through ACLs.

Dynamic Filtering

Definition:

A dynamic filtering firewall can **react to an emergent event** and update or create rules to deal with that event.

Reactions Can Be:

- **Positive** — allowing an internal user to engage in a specific activity upon request
- **Negative** — dropping all packets from a particular address when an increase in malformed packets is detected

Key Distinction from Static Filtering:

- Static filtering allows entire sets of one type of packet to enter in response to authorized requests
- Dynamic filtering allows only a **particular packet** with a **particular source, destination, and port address** to enter
- Opens and closes "doors" in the firewall based on packet header information

Key Point: Dynamic packet filters are an **intermediate form** between traditional static packet filters and application proxies.

Stateful Inspection Firewalls

Definition:
Also called **stateful firewalls** — keep track of each network connection between internal and external systems using a **state table**.

State Table:
Tracks the state and context of each packet in the conversation by recording which station sent what packet and when.

How It Works:

- Performs packet filtering like first generation firewalls
- Takes it a step further: can **expedite incoming packets** that are responses to internal requests
- If incoming packet cannot be matched in state table, refers to ACL to determine whether to allow

Example State Table Entry (Table 6-2):

Source Address	Source Port	Destination Address	Destination Port	Time Remaining	Total Time	Protocol
192.168.2.5	1028	10.10.10.7	80	2725	3600	TCP

Key Point: Many state table implementations allow a connection to remain in place for up to **60 minutes** without activity before entry is deleted.

Stateful Inspection — Advantages and Disadvantages

Advantages:

- Can track connectionless packet traffic (UDP and RPC traffic)
- Can expedite incoming packets that are responses to internal requests
- Dynamic stateful filtering firewalls keep a dynamic state table to make changes within predefined limits

Primary Disadvantage:

- Additional processing required to manage and verify packets against the state table
- This can leave the system vulnerable to **DoS or DDoS attack**
- In such an attack, system receives large number of external packets, slowing the firewall because it attempts to compare all incoming packets first to state table, then to ACL

Real-World Example ():

Table 9.2 shows an example stateful firewall connection state table with multiple established connections — source address, source port, destination address, destination port, and connection state.

Application-Level Gateways (Proxy Servers)

Definition (&):

Also known as **application-level firewall** or **application firewall** — frequently installed on a dedicated computer, separate from the filtering router, but commonly used in conjunction with a filtering router.

Also Known As: Proxy server — runs special software that acts as a proxy for a service request.

How It Works:

- Organization running a Web server can avoid exposing the server to direct user traffic by installing a proxy server
- Proxy receives requests for Web pages
- Accesses the Web server on behalf of the external client
- Returns requested pages to users
- Can store most recently accessed pages in internal cache (also called **cache servers**)

Key Benefit:

- Proxy server is placed in an **unsecured area** of the network or in the **DMZ** (demilitarized zone)
- It, rather than the Web server, is exposed to higher levels of risk
- Additional filtering routers can be implemented behind the proxy server

Primary Disadvantage:

- Designed for one or a few specific protocols
- Cannot easily be reconfigured to protect against attacks on other protocols
- Typically restricted to a single application (FTP, Telnet, HTTP, SMTP, SNMP)

Circuit Gateways

Definition (&):

Operates at the **transport layer**. Connections are authorized based on addresses.

How It Works:

- Like filtering firewalls, do not usually look at traffic flowing between one network and another
- But they **prevent direct connections** between one network and another
- Create **tunnels** connecting specific processes or systems on each side of the firewall
- Allow only authorized traffic (e.g., specific type of TCP connection for authorized users) in these tunnels

NIST SP 800-10 Description (John Wack):

"*A circuit-level gateway relays TCP connections but does no extra processing or filtering of the protocol. For example, the Telnet application gateway example provided here would be an example of a circuit-level gateway, since once the connection between the source and destination is established, the firewall simply passes bytes between the systems.*"

Another Example:

NNTP — NNTP server connects to firewall, internal systems' NNTP clients connect to firewall; firewall simply passes bytes.

Key Distinction: A circuit gateway is a firewall component often included in the category of application gateway, but it is in fact a **separate type** of firewall.

MAC Layer Firewalls

Definition (&):

Designed to operate at the **media access control (MAC) sublayer** of the data link layer (Layer 2) of the OSI network model.

Key Capability:

Enables firewalls to consider the **specific host computer's identity**, as represented by its MAC or network interface card (NIC) address in its filtering decisions.

How It Works:

- Links addresses of specific host computers to ACL entries
- ACL entries identify the specific types of packets that can be sent to each host
- Blocks all other traffic

OSI Model Position (Figure 6-6):

- Packet-filtering firewalls → Network layer (Layer 3)
- Application gateways → Application layer (Layer 7)
- Circuit gateways → Transport layer (Layer 4)
- MAC layer firewalls → Data link layer (Layer 2)

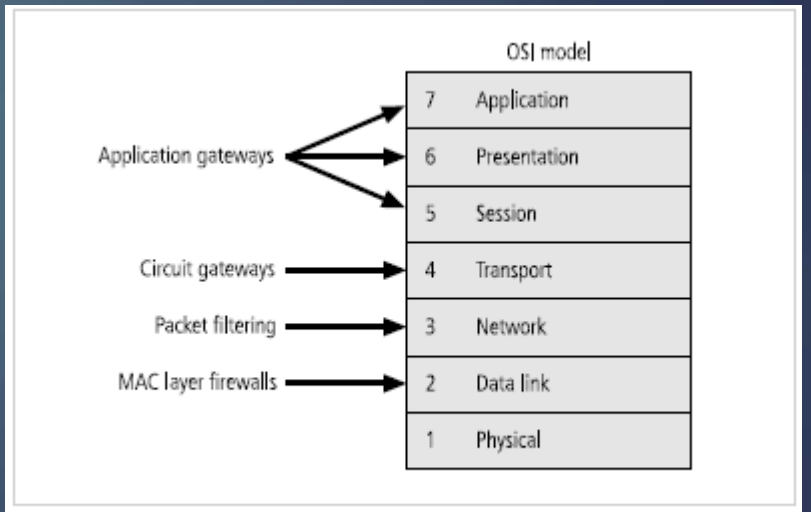


Figure 6-6 Firewall Types and the OSI Model

Bastion Hosts

Definition ():

A system identified by the firewall administrator as a **critical strong point** in the network's security. Typically serves as a platform for an application-level or circuit-level gateway.

Common Characteristics:

1. Hardware platform executes a **secure version of its operating system** — a hardened system
2. Only **essential services** are installed (proxy applications for DNS, FTP, HTTP, SMTP)
3. May require **additional authentication** before user access to proxy services
4. Each proxy supports only a **subset** of standard application's command set
5. Each proxy allows access only to **specific host systems**
6. Each proxy maintains **detailed audit information** — logging all traffic, each connection, duration
7. Each proxy module is a **very small software package** — easier to check for security flaws (mail proxy < 1000 lines vs. UNIX mail > 20,000 lines)
8. Each proxy is **independent** — can be uninstalled without affecting other proxies
9. Proxy generally performs **no disk access** other than reading initial configuration file — file system containing executable code can be made read-only
10. Each proxy runs as a **nonprivileged user** in a private and secured directory

Also Known As: Sacrificial host — stands as a sole defender on the network perimeter.

Host-Based and Personal Firewalls

Host-Based Firewall ():

A software module used to secure an **individual host**. Available in many operating systems or as an add-on package.

Advantages:

- Filtering rules can be **tailored to the host environment** — specific corporate security policies for servers
- Protection provided **independent of topology** — both internal and external attacks must pass through the firewall
- Used in conjunction with stand-alone firewalls, provides an **additional layer of protection**
- A new server can be added with its own firewall without altering network firewall configuration

Personal Firewall ():

Controls traffic between a personal computer or workstation and the Internet or enterprise network.

- Typically much **less complex** than server-based or stand-alone firewalls
- Primary role: **deny unauthorized remote access** to the computer
- Can monitor outgoing activity to detect and block worms and other malware

Example — Mac OS X Personal Firewall:

- All inbound connections denied except those user explicitly permits
- List of inbound services that can be selectively reenabled with port numbers (Personal file sharing 548/427, Windows sharing 139, Personal Web sharing 80/427, Remote login SSH 22, FTP 20-21, etc.)

Distributed Firewalls

Definition:

A distributed firewall configuration involves **stand-alone firewall devices plus host-based firewalls** working together under a **central administrative control**.

How It Works:

- Administrators configure host-resident firewalls on hundreds of servers and workstations
- Configure personal firewalls on local and remote user systems
- Tools let network administrator **set policies and monitor security** across entire network

Benefits:

- Protect against **internal attacks**
- Provide protection **tailored to specific machines and applications**
- Stand-alone firewalls provide **global protection** (internal firewalls + external firewall)

Key Concept — External and Internal DMZ:

- Web servers needing less protection (less critical information) could be placed in an **external DMZ**, outside the external firewall
- Protection provided by **host-based firewalls** on these servers

Important Aspect: Security monitoring — log aggregation and analysis, firewall statistics, fine-grained remote monitoring of individual hosts.

FIREWALL RULES AND NETWORK PROTECTION
Source and Destination Addresses

Packet-Filtering Firewall Examines:

- **Source IP address** — IP address of system that originated the IP packet (e.g., 192.178.1.1)
- **Destination IP address** — IP address of system the IP packet is trying to reach (e.g., 192.168.1.2)

Address Restrictions:

Rules designed to prohibit packets with certain addresses or partial addresses from passing through the device.

Accomplished Through ACLs:

Created and modified by firewall administrators.

Example (& Table 6-1):

- Rule: Any connection attempt from external computer/network device in **192.168.x.x** address range (192.168.0.0–192.168.255.255) is allowed
- Rule: **172.16.x.x** → **10.10.x.x** — Deny
- Rule: **192.168.x.x** → **10.10.10.25** — HTTP Allow
- Rule: **192.168.0.1** → **10.10.10.10** — FTP Allow

IP Spoofing Attack ():

- Intruder transmits packets from outside with source IP address field containing address of an internal host
- Hopes spoofed address allows penetration of systems employing simple source address security
- **Countermeasure:** Discard packets with an inside source address if packet arrives on external interface

System Ports and Network Protocols

Port Number Ranges (&):

- **System (well-known) ports:** 0 through 1023
- **User (registered) ports:** 1024 through 49151
- **Dynamic (private) ports:** 49152 through 65535

Select Well-Known Port Numbers (Table 6-5):

Port Number	Protocol
7	Echo
20	File Transfer [Default Data] (FTP)
21	File Transfer [Control] (FTP)
23	Telnet
25	Simple Mail Transfer Protocol (SMTP)
53	Domain Name Services (DNS)
80	Hypertext Transfer Protocol (HTTP)
110	Post Office Protocol version 3 (POP3)
161	Simple Network Management Protocol (SNMP)

Key Point: Some firewalls can filter packets by **protocol name** as opposed to protocol port number. For instance, Telnet protocol packets usually go to TCP port 23, but can sometimes be redirected to another much higher port number in an attempt to conceal the activity.

Allow and Deny Rules

Default Policies:

Policy	Description	Security Level	Preferred By
Default = Discard	That which is not expressly permitted is prohibited	More conservative; higher security	Businesses and government organizations
Default = Forward	That which is not expressly prohibited is permitted	Reduced security; easier to use	More open organizations, such as universities

Best Practices:

- All traffic from trusted network is **allowed out**
- Firewall device is **never directly accessible** from public network for configuration or management
- SMTP data is allowed to enter but routed to a **well-configured SMTP gateway**
- **All ICMP data should be denied** — ping service is common method for hacker reconnaissance
- **Telnet access to all internal servers** from public networks should be blocked
- When Web services offered outside firewall, **HTTP traffic blocked** from internal networks via proxy access or DMZ architecture
- **All data that is not verifiably authentic should be denied**

Firewall Rule Principle:
"*That which is not permitted is prohibited*" — also known as **expressly permitted rules**.

DMZ — Demilitarized Zone

Definition (&):
An intermediate area between a trusted network and an untrusted network.

Purpose:
- Proxy server placed in DMZ so it, rather than the Web server, is exposed to higher levels of risk
- Additional filtering routers can be implemented behind proxy server, limiting access to more secure internal system

Screened Subnet Firewalls (with DMZ) — Dominant Architecture Today:
- Architecture provides a DMZ
- DMZ can be a dedicated port on firewall device linking a single bastion host
- Or connected to a screened subnet

How Connections Are Routed (&):
1. Connections from outside/untrusted network routed through an **external filtering router**
2. Connections from outside/untrusted network routed **into — and then out of — a routing firewall** to the separate network segment known as the DMZ
3. Connections into trusted internal network allowed **only from DMZ bastion host servers**

Screened Subnet Performs Two Functions:
1. Protects DMZ systems and information from outside threats by providing a network of intermediate security
2. Protects internal networks by limiting how external connections can gain access

Extranet:
A segment of the DMZ where additional authentication and authorization controls are put into place to provide services not available to general public.
- **Example:** Online retailer allows anyone to browse catalog and place items in cart, but requires extra authentication/authorization when customer is ready to check out.

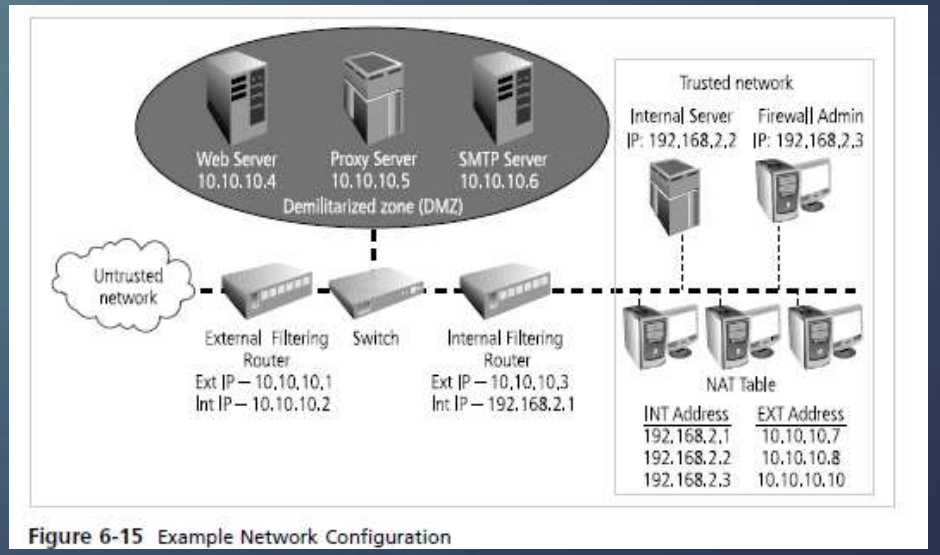


Figure 6-15 Example Network Configuration

NAT — Network Address Translation

Definition (&):
A method of mapping real, valid, external IP addresses to special ranges of **nonroutable internal IP addresses**, thereby creating another barrier to intrusion from external attackers.

Reserved Nonroutable Address Ranges (Table 6-4):

Class	From	To	CIDR Mask	Decimal Mask
Class A (24 Bit)	10.0.0.0	10.255.255.255	/8	255.0.0.0
Class B (20 Bit)	172.16.0.0	172.31.255.255	/12 or /16	255.240.0.0 or 255.255.0.0
Class C (16 Bit)	192.168.0.0	192.168.255.255	/16 or /24	255.255.0.0 or 255.255.255.0

Key Point: Messages sent with internal addresses within these three reserved ranges **cannot be routed externally**.

NAT Translation:

- NAT server translates between true external IP addresses and internally assigned nonroutable IP addresses
- Dynamically assigns addresses to internal communications
- Tracks conversations with sessions to determine which incoming message is a response to which outgoing traffic

Benefit: Internal computers are **not visible to the public network** — very much less likely to be scanned or compromised.

Firewall Architectures — Overview

Four Common Architectural Implementations (&):

Architecture	Description
Packet-Filtering Routers	Router at boundary between internal networks and external service provider; configured to reject unwanted packets
Screened Host Firewalls	Combines packet-filtering router with separate dedicated firewall (application proxy server)
Dual-Homed Host Firewalls	Bastion host contains two NICs — one to external network, one to internal network
Screened Subnet Firewalls (with DMZ)	Dominant architecture today; provides DMZ; two or more internal bastion hosts behind packet-filtering router

Configuration Depends On:

- Objectives of the network
- Organization's ability to develop and implement architectures
- Budget available for the function

Packet-Filtering Routers

Description:

Most organizations with an Internet connection have some form of router at the boundary between the organization's internal networks and external service provider.

How It Works:

- Router configured to reject packets that organization does not want to allow into network
- Simple but effective way to lower organization's risk from external attack

Drawbacks:

- Lack of auditing
- Lack of strong authentication
- Complexity of ACLs can degrade network performance

Figure 6-5:

Packet-filtering router used as simple firewall to filter data packets from inbound connections and allow outbound connections unrestricted access to public network.

Screened Host Firewalls

Description (&):

Combines the packet-filtering router with a **separate, dedicated firewall**, such as an application proxy server.

How It Works:

- Router **prescreens packets** to minimize network traffic and load on internal proxy
- Application proxy examines an application layer protocol (e.g., HTTP) and performs proxy services
- Separate host is often referred to as a **bastion host**

Key Point:

- Bastion host can be a rich target for external attacks and should be very thoroughly secured
- Even though bastion host/application proxy contains only cached copies of internal Web documents, it can still present a promising target
- Compromise of bastion host can disclose configuration of internal networks and provide attackers with internal information

Advantage:

- Requires external attack to compromise **two separate systems** before attack can access internal data
- Bastion host protects data more fully than router alone

Dual-Homed Host Firewalls

Description (&):

The next step up in firewall architectural complexity.

How It Works:

- Bastion host contains **two NICs** (network interface cards) rather than one
- One NIC connected to **external network**
- One NIC connected to **internal network**
- Provides an additional layer of protection
- All traffic must **physically go through the firewall** to move between internal and external networks

NAT Implementation:

- Implementation often makes use of NAT
- Creates yet another barrier to intrusion from external attackers

Additional Benefit:

- Ability to translate between many different protocols at their respective data link layers — Ethernet, token ring, FDDI, ATM

Downside:

- If dual-homed host is compromised, it can disable connection to external network
- As traffic volume increases, it can become overloaded
- But compared to more complex solutions, provides strong overall protection with **minimal expense**

Screened Subnet Firewalls (with DMZ) — Detailed

Description:

The **dominant architecture used today**.

Common Arrangement:

- Two or more internal bastion hosts behind a packet-filtering router
- Each host protecting the trusted network

Two General Models:

1. Two filtering routers, with one or more dual-homed bastion hosts between them
2. Connections routed as follows:
    - Connections from outside/untrusted network → external filtering router
    - Connections from outside/untrusted network → routing firewall → DMZ
    - Connections into trusted internal network → allowed only from DMZ bastion host servers

Key Point:

Screened subnet is an entire network segment that performs **two functions**:

1. Protects DMZ systems and information from outside threats
2. Protects internal networks by limiting how external connections can gain access

Cost Consideration:

Extremely secure, but can be **expensive to implement** and **complex to configure and manage**. The value of the information it protects must justify the cost.

Firewall Rule Ordering — Overview

Key Principle (&):

Rules are processed **in order**. The firewall employs the **first rule that applies** to any given packet.

Why Order Matters:

- The more rules a firewall must process to find one that applies, the **slower** the firewall will run
- Most widely applicable rules should come **first**
- Misplacement of a particular rule can result in **unforeseen results**

Real-World Example (&):

One organization installed a new **$50,000 firewall**, only to discover that the security provided was **too perfect** — nothing was allowed in, and nothing was allowed out! It wasn't until firewall administrators realized that the rule base was **out of sequence** that the problem was resolved.

Best Practice:

- Rules that can be evaluated quickly and govern broad access are performed **before** ones that may take longer to evaluate and affect fewer cases
- The **cleanup rule** (deny all) should be the **last rule**

Firewall Rule Sets — Examples

Rule Set 1: Responses to internal requests are allowed

Source Address	Source Port	Destination Address	Destination Port	Action
Any	Any	10.10.10.0/24	>1023	Allow

Rule Set 2: Firewall device is never accessible directly from public network

Source Address	Source Port	Destination Address	Destination Port	Action
Any	Any	10.10.10.1	Any	Deny
Any	Any	10.10.10.2	Any	Deny
10.10.10.1	Any	Any	Any	Deny
10.10.10.2	Any	Any	Any	Deny

Rule Set 3: All traffic from trusted network is allowed out

Source Address	Source Port	Destination Address	Destination Port	Action
10.10.10.0	Any	Any	Any	Allow

Firewall Rule Sets — Examples

Rule Set 4: SMTP data routed to well-configured SMTP gateway

Source Address	Source Port	Destination Address	Destination Port	Action
Any	Any	10.10.10.6	25	Allow

Rule Set 5: ICMP (ping) denied

Source Address	Source Port	Destination Address	Destination Port	Action
10.10.10.0	Any	Any	7	Allow
Any	Any	10.10.10.0	7	Deny

Rule Set 6: Telnet access to internal servers blocked

Source Address	Source Port	Destination Address	Destination Port	Action
10.10.10.0	Any	10.10.10.0	23	Allow
Any	Any	10.10.10.0	23	Deny

Firewall Rule Sets — Examples

Rule Set 7: HTTP traffic to Web server

Source Address	Source Port	Destination Address	Destination Port	Action
Any	Any	10.10.10.4	80	Allow

Rule Set 8: Cleanup rule — deny all

Source Address	Source Port	Destination Address	Destination Port	Action
Any	Any	Any	Any	Deny

Complete External Filtering Firewall Inbound Rule Set

Rule #	Source Address	Source Port	Destination Address	Destination Port	Action
1	10.10.10.0	Any	Any	Any	Deny
2	Any	Any	10.10.10.1	Any	Deny
3	Any	Any	10.10.10.2	Any	Deny
4	10.10.10.1	Any	Any	Any	Deny
5	10.10.10.2	Any	Any	Any	Deny
6	Any	Any	10.10.10.0	>1023	Allow
7	Any	Any	10.10.10.6	25	Allow
8	Any	Any	10.10.10.0	7	Deny
9	Any	Any	10.10.10.0	23	Deny
10	Any	Any	10.10.10.4	80	Allow
11	Any	Any	Any	Any	Deny

Key Point:

- Rule 1 prevents **spoofing of internal IP addresses**
- Rules 2–5 prohibit direct communications to or from firewall itself
- Rule 6 allows responses to internal communications
- Rules 8 and 9 are actually unnecessary as cleanup rule would handle their tasks
- If heavy traffic to HTTP server expected, move HTTP server rule closer to top (e.g., position of rule 2)

Complete External Filtering Firewall Outbound Rule Set

Rule #	Source Address	Source Port	Destination Address	Destination Port	Action
1	10.10.10.12	Any	10.10.10.0	Any	Allow
2	Any	Any	10.10.10.1	Any	Deny
3	Any	Any	10.10.10.2	Any	Deny
4	10.10.10.1	Any	Any	Any	Deny
5	10.10.10.2	Any	Any	Any	Deny
6	10.10.10.0	Any	Any	Any	Allow
7	Any	Any	Any	Any	Deny

Key Point:

- First rule allows firewall/system/network administrator to access any device, including firewall
- Since rule is on outbound side, no need to worry about external attackers or spoofers
- Next four rules prohibit access to and by firewall itself
- Remaining rules allow outbound communications and deny all else

Internal Filtering Firewall Rule Sets

Table 6-18 — Internal Filtering Firewall Inbound Interface:

Rule #	Source Address	Source Port	Destination Address	Destination Port	Action
1	Any	Any	10.10.10.3	Any	Deny
2	Any	Any	10.10.10.7	Any	Deny
3	10.10.10.3	Any	Any	Any	Deny
4	10.10.10.7	Any	Any	Any	Deny
5	Any	Any	10.10.10.0	>1023	Allow
7	10.10.10.5	Any	10.10.10.8	Any	Allow
8	Any	Any	Any	Any	Deny

Internal Filtering Firewall Rule Sets

Table 6-19 — Internal Filtering Firewall Outbound Interface:

Rule #	Source Address	Source Port	Destination Address	Destination Port	Action
1	Any	Any	10.10.10.3	Any	Deny
2	Any	Any	192.168.2.1	Any	Deny
3	10.10.10.3	Any	Any	Any	Deny
4	192.168.2.1	Any	Any	Any	Deny
5	Any	Any	192.168.2.0	>1023	Allow
6	192.168.2.0	Any	Any	Any	Allow
8	Any	Any	Any	Any	Deny

Key Point:

- 192.168.2.x network is **unrouteable** — external communications handled by NAT server, which maps internal (192.168.2.0) addresses to external (10.10.10.0) addresses
- Prevents attacker from compromising internal box and accessing internal network with it
- Exception is proxy server (rule 7 in Table 6-19 on internal router's inbound interface), which should be very carefully configured
- No ping and Telnet rules in Tables 6-18 or 6-19 because external firewall filters these external requests out.

Content Filters

Definition (&):

A software filter — technically **not a firewall** — that allows administrators to restrict access to content from within a network.

Also Known As: Reverse firewalls — primary purpose is to restrict internal access to external material.

Two Components:

1. **Rating** — like a set of firewall rules for Web sites; common in residential content filters
2. **Filtering** — method used to restrict specific access requests to identified resources

How It Works:

- Essentially a set of scripts or programs that restricts user access to certain networking protocols and Internet locations
- Restricts users from receiving general types or specific examples of Internet content

Exclusive vs. Inclusive Mode:

- **Exclusive mode:** Certain sites specifically excluded — problem is there may be thousands of sites to exclude, more added every hour
- **Inclusive mode:** Works from list of sites specifically permitted — user must submit request to content filter manager

Newer Models: Protocol-based, examining content as it is dynamically displayed, restricting or permitting access based on logical interpretation of content.

Common Uses:

- Restrict users from accessing Web sites with non-business related material (pornography)
- Deny incoming spam e-mail

Examples: NetNanny, SurfControl (small add-on programs); Novell Border Manager (corporate applications)

Selecting the Right Firewall

Questions to Consider (&):

1. **Which type of firewall technology offers the right balance between protection and cost** for the needs of the organization?
2. **What features are included in the base price?** What features are available at extra cost? Are all cost factors known?
3. **How easy is it to set up and configure** the firewall? How accessible are the staff technicians who can competently configure the firewall?
4. **Can the candidate firewall adapt to the growing network** in the target organization?

Key Priorities:

- **Most important:** Extent to which firewall design provides required protection
- **Second most important:** Cost

Key Point: As with all security decisions, certain compromises may be necessary to provide a viable solution under budgetary constraints stipulated by management.

Configuring and Managing Firewalls

Best Practices (&):

- All traffic from trusted network is **allowed out**
- Filtering and logging of outbound traffic can be implemented when required by specific organizational policies
- Firewall device is **never directly accessible** from public network for configuration or management
- Almost all administrative access to firewall device is **denied to internal users** as well
- Only authorized firewall administrators access device through **secure authentication mechanisms** — preferably cryptographically strong authentication and two-factor access control
- **SMTP data** allowed to enter but routed to well-configured SMTP gateway
- **All ICMP data should be denied** — ping service is common method for hacker reconnaissance
- **Telnet access to all internal servers** from public networks should be blocked
- At the very least, Telnet access to DNS server should be blocked to prevent illegal zone transfers and prevent attackers from taking down entire network
- When Web services offered outside firewall, **HTTP traffic should be blocked** from internal networks through proxy access or DMZ architecture
- **All data that is not verifiably authentic should be denied**
- When attempting to convince packet-filtering firewalls to permit malicious traffic, attackers frequently put an internal address in source field — **set rules so external firewall blocks all inbound traffic with an organizational source address**

Key Insight:

"*When security rules conflict with the performance of business, security often loses.*" — Organizations are much more willing to live with potential risk than certain failure.

Discussion Questions

1. What are the three design goals of a firewall?
2. Explain the four techniques firewalls use to control access and enforce security policy.
3. Compare and contrast packet-filtering firewalls, application-level gateways, and circuit gateways.
4. What is stateful inspection? How does it improve upon simple packet filtering?
5. Describe the five generations of firewalls.
6. What is a bastion host? List its common characteristics.
7. Explain the difference between a screened host firewall and a dual-homed host firewall.
8. What is a DMZ? Why is it used?
9. How does NAT provide additional security?
10. Why is firewall rule ordering important? What happens if rules are out of sequence?
11. Analyze the complete external filtering firewall inbound rule set (Table 6-16). Why is rule 1 (deny 10.10.10.0) placed first?
12. What are the limitations of firewalls? Why can't they provide complete security?

Thank you